MedBridge Health, Inc.
Acceptable Use Policy (AUP)

1. Purpose

The purpose of this policy is to explain how MedBridge Health employees and contractors are expected to use company devices, applications, networks, and other technology resources.

Since MedBridge Health provides telehealth services and handles sensitive patient information, employees need to use company systems responsibly to help prevent unauthorized access, data breaches, and other cybersecurity threats.

This policy covers what employees are allowed and not allowed to do when using company technology, including accessing patient records, using email and messaging platforms, and working remotely.

It also helps make sure that employees understand their responsibilities when handling Protected Health Information (PHI) and other sensitive company information.

2. Scope

This policy applies to all MedBridge Health employees, contractors, temporary workers, and authorized third-party personnel who use or have access to company devices, networks, applications, or information.

It covers employees working at the San Francisco office and those working remotely. Anyone accessing company systems must follow the same security requirements, regardless of where they are working.

The policy covers the following:

Company Devices:	Laptops, workstations, mobile devices, and other equipment used for company business.
Cloud Infrastructure:	Amazon Web Services (AWS) and other cloud services used to support company operations.
Healthcare Applications:	Patient applications, clinician portals, and Electronic Health Records (EHR) systems.
Company Accounts:	Okta, Google Workspace, and other accounts used to access company resources.
Communication Platforms:	Company email, Slack, Zoom for Healthcare, and approved messaging services.
Networks:	The San Francisco office network, approved remote connections, and other networks used to access company systems.
Sensitive Information:	Protected Health Information (PHI), Personally Identifiable Information (PII), employee records, and confidential business information.

Personal devices are not allowed to access systems containing PHI. Employees must use authorized, company-managed devices when accessing patient records or other restricted healthcare information.

This policy applies whenever company resources are used, including while employees are working remotely.

Any exceptions must follow the approval process outlined in Section 5 of this policy.

3. Roles and Responsibilities

Everyone who uses MedBridge Health's systems and technology has a responsibility to follow this policy and help protect company and patient information.

Since MedBridge Health does not have a dedicated cybersecurity team, the IT Manager, part-time virtual Chief Information Security Officer (vCISO), and department leaders share responsibility for overseeing how company technology is used.

3.1 Security Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer (CEO)	Approves the Acceptable Use Policy and provides oversight when major security issues need management attention.
Chief Technology Officer (CTO)	Oversees the security of company applications, AWS infrastructure, and other technical systems.
Virtual Chief Information Security Officer (vCISO)	Maintains the Acceptable Use Policy, reviews security risks, and makes sure the policy stays aligned with the company's security requirements.
IT Manager	Manages company devices, user accounts, access permissions, and investigates reports of improper technology use.
Privacy Officer (COO)	Reviews situations involving patient information and helps determine whether any HIPAA privacy requirements have been violated.
HR Manager	Makes sure employees receive security training, understand the policy, and helps address employee policy violations.
Employees and Contractors	Use company technology responsibly, protect sensitive information, and report suspicious activity or potential policy violations.

3.2 Employee and Contractor Responsibilities

Employees and contractors are expected to use MedBridge Health's technology only for authorized business activities and follow the company's security requirements.

This includes:

- Using their own assigned accounts when accessing company systems.
- Keeping passwords and authentication information private.
- Accessing patient records only when needed for their job.
- Using approved devices and applications for company work.
- Making sure company devices are locked when unattended.
- Reporting lost devices, suspicious emails, or possible security incidents to the IT Manager or vCISO as soon as possible.
- Following company security requirements when working remotely.

Employees and contractors must not share their accounts with coworkers, family members, or anyone else.

3.3 Management Responsibilities

Department managers are responsible for making sure that employees understand the Acceptable Use Policy and follow the requirements that apply to their work.

If an employee reports a security concern or possible policy violation, the manager must notify the IT Manager or vCISO so the situation can be reviewed.

The vCISO and IT Manager will work with the appropriate department leaders to address identified issues and recommend improvements when necessary.

---

4. Policy Statements

MedBridge Health employees and contractors must use company devices, applications, networks, and information responsibly.

These requirements help protect patient information, prevent unauthorized access, and reduce security risks caused by improper use of company technology.

4.1 Acceptable Use of Company Technology

1. Employees must use company devices, applications, and network resources for approved business activities.
2. Limited personal use of company devices is allowed as long as it does not interfere with work, create security risks, or violate company policies.
3. Employees must only install software or applications that have been approved by the IT Manager.
4. Company devices and accounts must not be shared with unauthorized individuals, including family members.

5. Employees must report lost or stolen company devices to the IT Manager or vCISO immediately after discovering the loss.

4.2 Protection of Patient and Company Information

1. Employees must only access patient records when necessary to perform their assigned job responsibilities.
2. Protected Health Information (PHI) must only be stored, processed, or shared through approved systems.
3. Employees must not send PHI through personal email accounts, Slack, or other unauthorized messaging platforms.
4. Patient records, confidential company documents, and other restricted information must not be uploaded to public AI chatbots or unapproved cloud storage services.
5. Employees must not download or copy patient records to personal devices or unauthorized storage locations.
6. Sensitive information must not be shared with individuals who do not have an approved business need to access it.

4.3 Account and Device Security

1. Employees must use their own assigned accounts when accessing company systems.
2. Employees must not share passwords, MFA codes, or other authentication information with anyone.
3. Multi-Factor Authentication (MFA) must be used when accessing systems containing PHI and administrative accounts.
4. Company devices must automatically lock after five minutes of inactivity.
5. Employees must manually lock their devices whenever they leave them unattended.
6. Only authorized, company-managed devices may access systems containing PHI.
7. Employees must not disable antivirus software, endpoint protection, or other security controls without approval from the IT Manager.

4.4 Email, Internet, and Communication

1. Employees must use approved company email accounts for business communications.
2. Employees must not open suspicious attachments or click links in emails they believe may be phishing attempts.
3. Suspicious emails must be reported to the IT Manager or vCISO.
4. Company email and communication platforms must not be used for harassment, illegal activities, or sending unauthorized bulk messages.
5. Employees must not use company technology to download pirated software or access illegal content.
6. Confidential business information and patient information must not be posted on social media or other public platforms.

4.5 Remote Work and Home Network Security

1. Remote employees must use authorized company-managed devices when accessing patient information.
2. Employees working remotely must connect through Wi-Fi networks protected by WPA2-AES or WPA3 encryption.
3. Employees must not access PHI through unsecured public Wi-Fi networks unless using an approved secure connection method.
4. Employees must prevent family members, roommates, or visitors from accessing company devices and information.
5. Employees must make sure patient information cannot be viewed or overheard by unauthorized individuals during remote work.
6. Employees must use company-approved remote access tools when required by the IT Manager.

4.6 Prohibited System and Network Activities

The following activities are prohibited unless specifically authorized for legitimate business or security purposes:

1. Attempting to access systems, accounts, or information without permission.
2. Performing network scans, penetration tests, or vulnerability assessments without written authorization.
3. Disabling or bypassing security controls without approval.
4. Introducing malware, ransomware, or other malicious software into company systems.
5. Attempting to interfere with or disrupt company networks, applications, or services.
6. Installing unauthorized remote access software or monitoring tools.
7. Using company systems to access information unrelated to assigned job responsibilities.

4.7 Security Monitoring and Reporting

1. MedBridge Health may monitor and review company-managed devices, accounts, and network activity for legitimate security and compliance purposes, subject to applicable laws.
2. Employees must report suspected unauthorized access, lost devices, phishing attempts, or other potential security incidents immediately after discovery.
3. The IT Manager and vCISO are responsible for reviewing reported security concerns and coordinating appropriate actions.
4. Employees must cooperate with authorized security investigations and compliance reviews.

---

5. Exceptions

MedBridge Health understands that there may be situations where employees or departments need an exception to certain security requirements because of technical limitations or business needs.

Any exception must be reviewed and approved before employees are allowed to operate outside this policy. Exceptions cannot override legal or regulatory requirements, including HIPAA.

5.1 Exception Request Process

1. Employees or department managers must submit an exception request explaining which requirement cannot be followed and why the exception is needed.
2. The request must identify the affected systems, devices, or information, along with any potential security risks.
3. The vCISO must review the request, assess the risks, and recommend additional security measures when necessary.
4. The appropriate system owner must review the business reason for the exception.
5. The CEO must approve exceptions involving high or critical risks. Lower-risk exceptions may be approved by the vCISO.
6. Approved exceptions must be documented in the company's exception register and include an expiration date.

5.2 Exception Monitoring and Review

The vCISO must review approved exceptions at least every 90 days to make sure the risks are still understood and any required security measures remain in place.

Exceptions must be reviewed again before they expire. If an exception is no longer needed, the employee or department must return to following the original policy requirement.

Exceptions involving Protected Health Information (PHI) must also be reviewed by the Privacy Officer to make sure they do not conflict with applicable HIPAA requirements.

---

6. Enforcement

All MedBridge Health employees, contractors, and authorized third-party personnel are expected to follow the requirements outlined in this Acceptable Use Policy.

Failing to follow these requirements could put patient information, company systems, and business operations at risk.

If someone violates this policy, MedBridge Health will review the situation and determine the appropriate action based on how serious the violation is.

Depending on the situation, corrective actions may include:

- **Additional Security Training:** Employees may be required to complete additional training to better understand how to use company technology securely.
- **Written Warning:** Employees may receive a formal warning for failing to follow company security requirements.
- **Access Restrictions:** Access to certain systems, applications, or company resources may be temporarily restricted or removed.
- **Disciplinary Action:** Serious or repeated violations may result in further disciplinary action, including termination of employment.
- **Contractual Action:** Contractors or third-party vendors who violate the policy may face consequences under their agreements with MedBridge Health.

The HR Manager will work with department leaders when employee disciplinary action is required.

The IT Manager and vCISO will review security-related violations and recommend actions to address any identified risks.

If a violation involves patient information, the Privacy Officer must also be notified to determine whether further investigation or reporting is required.

MedBridge Health will handle policy violations consistently and consider the severity of the incident, its impact, and whether the violation was intentional or accidental.

---

7. Related Policies and References

MedBridge Health's Acceptable Use Policy is based on cybersecurity standards, healthcare regulations, and security best practices that provide guidance on using company technology and protecting sensitive information.

These references help make sure the policy stays consistent with the company's overall cybersecurity program.

7.1 Related Security Policies

The following policies support MedBridge Health's Acceptable Use Policy:

- **Information Security Policy:** Establishes the company's overall security requirements for protecting information systems, managing cybersecurity risks, and maintaining security responsibilities.
- **Password and Authentication Policy:** Defines password requirements, Multi-Factor Authentication (MFA), and secure account management practices.

- **Incident Response Policy:** Explains how employees should report potential security incidents and how the company will investigate and respond to them.

7.2 Regulations, Frameworks, and Standards

Reference	Purpose
HIPAA Security Rule (45 CFR Part 164, Subpart C)	Establishes security requirements for protecting electronic Protected Health Information (ePHI).
HIPAA Privacy Rule	Establishes requirements for protecting patient information and controlling how PHI is used and disclosed.
HITECH Act	Supports healthcare information security and breach notification requirements.
NIST Cybersecurity Framework (CSF) 2.0	Provides guidance for managing cybersecurity risks and improving security practices.
ISO/IEC 27001:2022	Provides requirements for establishing and managing an information security management system.
SANS Acceptable Use Standard (April 2025)	Provides guidance on acceptable use of company systems, devices, networks, email, and other technology resources.

7.3 Policy Review and Updates

The vCISO is responsible for reviewing this policy at least once every 12 months to make sure it remains relevant to MedBridge Health's security needs.

The policy must also be reviewed when major changes occur, such as new technology implementations, changes to healthcare regulations, or newly identified cybersecurity risks.

Any major changes must be approved by the CEO before the updated policy takes effect.

Employees and contractors must be informed of policy updates that affect how they use company technology.

8. Definitions

This section explains some of the cybersecurity and compliance terms used throughout MedBridge Health's Acceptable Use Policy.

Term	Definition
Acceptable Use Policy (AUP)	A policy that explains how employees and other authorized users are allowed to use company technology and information.
Protected Health Information (PHI)	Patient health information that can be used to identify an individual and is protected under HIPAA.
Electronic Protected Health Information (ePHI)	PHI that is created, stored, received, or transmitted electronically.
Personally Identifiable Information (PII)	Information that can be used to identify someone, such as their name, date of birth, or Social Security number.
Multi-Factor Authentication (MFA)	A security method that requires two or more authentication factors to verify a user's identity.
Virtual Chief Information Security Officer (vCISO)	An external security professional who helps manage an organization's cybersecurity program and security strategy.
Authorized User	An employee, contractor, or approved third party who has permission to access company systems or information.
Company-Managed Device	A device that is approved, configured, and maintained by MedBridge Health's IT Manager or authorized technical staff.
Unauthorized Access	Accessing systems, applications, accounts, or information without the required permission.
Security Incident	An event that could affect the confidentiality, integrity, or availability of company systems or information.
Remote Work	Performing job responsibilities outside the company's office while accessing approved company systems and resources.
Policy Exception	A formally approved, temporary allowance to operate outside a specific security policy requirement.
Third-Party Vendor	An external company or service provider that supports MedBridge Health's business operations.

9. Document Control

This section documents the ownership, approval, and review requirements for MedBridge Health's Acceptable Use Policy.

The vCISO is responsible for maintaining the policy and making sure it is reviewed regularly. The CEO is responsible for approving the policy before it officially takes effect.

9.1 Policy Information

Field	Details
Policy Title	Acceptable Use Policy
Organization	MedBridge Health, Inc.
Policy ID	MBH-AUP-002
Version	1.0
Policy Owner	Virtual Chief Information Security Officer (vCISO)
Policy Approver	Chief Executive Officer (CEO)
Effective Date	Pending Approval
Last Review Date	Not Yet Reviewed
Next Review Date	12 months after approval
Review Frequency	Annually
Policy Status	Draft — Pending Approval

9.2 Policy Review and Approval

The vCISO must review this policy at least once every 12 months or whenever significant changes occur that could affect how MedBridge Health employees and contractors use company technology.

Any updates must be documented and submitted to the CEO for approval before the revised policy takes effect.

Employees and contractors must be informed of any changes that affect their security responsibilities or the acceptable use of company resources.

9.3 Version History

Version	Date	Description	Updated By
1.0	November 2, 2026	Initial draft of the Acceptable Use Policy	vCISO (Simulated)

9.4 Document Disclaimer

This Acceptable Use Policy was created for MedBridge Health, Inc., a fictional healthcare organization, as part of a hands-on GRC lab. All policy requirements, roles, and approval processes are simulated by Andree Salvo and they do not represent any official implemented security programs.